

コーディング規約

本プロジェクトにおいて遵守した主要なコーディング規約は以下の通りです。

1. 命名規則

- **変数名・関数名:** スネークケース（snake_case）を採用する。（例: `$product_name`, `get_admin_products()`）
- **定数名:** アップースネークケース（UPPER_SNAKE_CASE）を採用する。（例: `DB_HOST`, `UPLOAD_DIR`）
- **ファイル名:** スネークケース（snake_case）を採用する。（例: `ec_site_model.php`）

2. インデント・フォーマット

- インデントは **半角スペース2文字** を使用し、タブ（Tab）は使用しない。
- `if`, `for`, `foreach`, `while`, 関数定義などの開き波括弧 `{` は、ステートメントと同じ行に記述する。

3. セキュリティ対策（必須事項）

- **SQLインジェクション対策:** データベースとの通信にはすべて PDO のプリペアドステートメント（`prepare -> execute`）を使用する。SQL文字列の直接結合は厳禁。
- **XSS（クロスサイトスクリプティング）対策:** ユーザー入力やデータベースから取得したデータを HTML画面に出力する際は、必ず `htmlspecialchars`（本プロジェクトではラッパー関数 `h()`）を通すこと。
- **CSRF・アクセス制御:** 各ページの先頭で `is_login()` 等を呼び出し、未ログインユーザーの不正な画面アクセスを防止する。

4. コメント・ドキュメント

- 各関数（モデルやビューなど）の上部には、PHPDoc形式（`/** ... */`）で関数の役割、引数、戻り値の概要を記述する。
- 複雑なロジックブロックには、処理の意図を簡潔なコメントで明記する。

5. MVC・ディレクトリ構成

- ユーザーが直接アクセスする公開ディレクトリ（`htdocs`）には画面ファイルのみを配置する。
- データベース処理（モデル）、共通画面パーツ（ビュー）、ルーティング等のコアロジックは非公開の `include` ディレクトリに配置し、セキュリティと関心の分離を担保する。